

MODUL IV

Autentikasi dan Otorisasi

Tujuan

- ◆ Mahasiswa dapat menginstal dan mengkonfigurasi Laravel Sanctum untuk API token.
- ◆ Mahasiswa dapat menambahkan kolom `role` pada tabel `users` dan memperbarui Model `User`.
- ◆ Mahasiswa dapat membuat endpoint `register & login` yang mengeluarkan token.
- ◆ Mahasiswa dapat melindungi route API dengan middleware `auth:sanctum`.
- ◆ Mahasiswa dapat membuat dan mendaftarkan middleware kustom `role` untuk membatasi akses.
- ◆ Mahasiswa dapat menguji skenario bahwa hanya admin dapat melakukan delete.

Materi

1. Autentikasi API dengan Laravel Sanctum
 - 1.1. Laravel Sanctum menyediakan token-based authentication ringan untuk SPA, mobile, dan simple token apps.
 - 1.2. Perbedaan dengan Passport: Sanctum tidak memerlukan OAuth2, lebih sederhana.
 - 1.3. Alur dasar:
 - Client mendaftar/login → server membuat personal access token → client simpan token.
 - Setiap request API sertakan header `Authorization: Bearer {token}`.
 - Sanctum mem-verifikasi token, mengisi `Auth::user()`.
2. Konfigurasi Sanctum
 - 2.1. Instalasi sanctum secara tidak langsung sudah dilaksanakan pada praktikum sebelumnya. Begitu pula migration untuk tabel `personal_access_tokens`.
 - 2.2. Tambahkan trait `HasApiTokens` di Model `User`.
 - 2.3. Tambahkan middleware di `app/bootstrap.php`:
 - ✓ Di `$middlewareGroups['api']` tambahkan `\Laravel\Sanctum\Http\Middleware\EnsureFrontendRequestsAreStateful::class` jika SPA.
 - ✓ Pastikan `auth:sanctum` route middleware tersedia.
3. Menyiapkan role dasar di User
 - 3.1. Kita akan pakai dua role: "admin" dan "user".

- 3.2. Tambahkan kolom role di tabel users (enum atau string).
- 3.3. Default registrasi akan set role="user".
- 3.4. Admin dapat di-create manual via database/seed.
4. Custom Middleware untuk otorisasi role
 - 4.1. Buat middleware RoleMiddleware yang menerima parameter nama role.
 - 4.2. Di method handle():
 - ✓ Ambil user via Auth::user()
 - ✓ Jika user->role !== role yang diizinkan, return 403 JSON.
 - ✓ Else, lanjutkan request.
 - 4.3. Daftarkan middleware di \$routeMiddleware di bootstrap:


```
'role' => \App\Http\Middleware\RoleMiddleware::class,
```
 - 4.4. Terapkan middleware pada route delete:


```
->middleware(['auth:sanctum', 'role:admin'])
```

Praktikum

1. Pastikan Anda switch dari branch main ke branch feature/auth-sanctum:

```
cd C:\laragon\www\inventory
git checkout main
git pull origin main
git checkout -b feature/auth-sanctum
```

2. Update Model User

File: app/Models/User.php

```
<?php
...
class User extends Authenticatable {
    use HasApiTokens, Notifiable;
    protected $fillable = [
        'name', 'email', 'password', 'role',
    ];
    protected $hidden = [
        'password', 'remember_token',
    ];
}
```

3. Tambah kolom role di users table

Buat migration:

```
php artisan make:migration add_role_to_users_table \
--table=users
```

File: database/migrations/xxxxxx_add_role_to_users_table.php

```
<?php
...
return new class extends Migration {
    public function up() {
```

```

        Schema::table('users', function (Blueprint $table) {
            $table->string('role')
                ->default('user')
                ->after('password');
        });
    }
    public function down() {
        Schema::table('users', function (Blueprint $table) {
            $table->dropColumn('role');
        });
    }
};

```

Jalankan migration:

```
php artisan migrate
```

4. Buat AuthController

```
php artisan make:controller AuthController
```

File: app/Http/Controllers/AuthController.php

```
<?php
```

```
...
```

```

class AuthController extends Controller {
    public function register(Request $req) {
        $validated = $req->validate([
            'name'      => 'required|string|max:255',
            'email'     => 'required|email|unique:users',
            'password' => 'required|string|min:6|confirmed',
        ]);
        $user = User::create([
            'name'      => $validated['name'],
            'email'     => $validated['email'],
            'password' => Hash::make($validated['password']),
            // role default 'user'
        ]);
        $token = $user->createToken('api-token')->plainTextToken;
        return response()->json([
            'status' => 'success',
            'data'   => ['user'=>$user, 'token'=>$token],
            'message' => 'User registered'
        ], 201);
    }
    public function login(Request $req) {
        $req->validate([
            'email' => 'required|email',
            'password' => 'required',
        ]);
        $user = User::where('email', $req->email)->first();
        if (! $user || ! Hash::check($req->password,
            $user->password)) {
            throw ValidationException::withMessages([
                'email' => ['The provided credentials are incorrect.']
            ]);
        }
    }
}

```

```

        // Revoke old tokens?
        $user->tokens()->delete();
        $token = $user->createToken('api-token')->plainTextToken;
        return response()->json([
            'status' => 'success',
            'data'    => ['user'=>$user, 'token'=>$token],
            'message' => 'User logged in'
        ]);
    }
}

```

5. Daftarkan route auth

File: routes/api.php

```

<?php
use Illuminate\Support\Facades\Route;
Route::post('register',
    'App\Http\Controllers\AuthController@register');
Route::post('login',
    'App\Http\Controllers\AuthController@login');
// Protected routes ditambahkan nanti

```

6. Proteksi route dengan Sanctum

Ubah routing item & category di bawah auth:sanctum:

```

Route::middleware('auth:sanctum')->group(function(){
    Route::apiResource('categories',
        'App\Http\Controllers\CategoryController');
    Route::apiResource('items',
        'App\Http\Controllers\ItemController');
});

```

7. Buat middleware Role

php artisan make:middleware RoleMiddleware

File: app/Http/Middleware/RoleMiddleware.php

```

<?php
namespace App\Http\Middleware;
use Closure;
use Illuminate\Http\Request;
class RoleMiddleware {
    ...
    public function handle(Request $request, Closure $next,
        string $role) {
        $user = $request->user();
        if (! $user || $user->role !== $role) {
            return response()->json([
                'status' => 'error',
                'data'    => null,
                'message' => 'Unauthorized. Role '.$role.' required.'
            ], 403);
        }
        return $next($request);
    }
}

```

8. Daftarkan middleware di bootstrap

File: app/bootstrap.php

```
protected $routeMiddleware = [
    ...
    'role' => \App\Http\Middleware\RoleMiddleware::class,
];
```

9. Terapkan role:admin pada delete routes

File: routes/api.php

```
Route::middleware('auth:sanctum')->group(function(){
    Route::apiResource('categories',
        'App\Http\Controllers\CategoryController')
        ->except(['destroy']);
    Route::delete('categories/{category}',
        'App\Http\Controllers\CategoryController@destroy')
        ->middleware('role:admin');
    Route::apiResource('items',
        'App\Http\Controllers\ItemController')
        ->except(['destroy']);
    Route::delete('items/{item}',
        'App\Http\Controllers\ItemController@destroy')
        ->middleware('role:admin');
});
```

10. Uji di Postman

10.1. POST /api/register → dapat token, role=user

10.2. POST /api/login → dapat token

10.3. Sertakan header Authorization: Bearer {token} pada request selanjutnya

10.4. Coba DELETE /api/items/1 dengan user biasa → 403

10.5. Ubah role user di database menjadi "admin" (via phpMyAdmin) → ulangi DELETE → 204

11. Commit & Push

```
git add .
git commit -m "Add Laravel Sanctum auth and role middleware"
git push -u origin feature/auth-sanctum
```

12. Pull Request

12.1. Buka Repository di GitHub

- Pergi ke <https://github.com/USERNAME/inventory>
- Kamu akan melihat notifikasi kuning: "**feature/auth-sanctum had recent pushes**" → klik "**Compare & pull request**"

12.2. Isi Form Pull Request

- Base branch: main (branch tujuan merge)
- Compare branch: feature/auth-sanctum (branch kamu)
- Title: Isi judul PR
- Setelah form diisi, klik tombol "Create pull request"

12.3. Review Kode (Melihat Perubahan)

- Klik tab "Files changed"
- Lihat perubahan kode:
 - Warna hijau = baris kode yang ditambah
 - Warna merah = baris kode yang dihapus

12.4. Merge Pull Request

- Klik tombol "Merge pull request"
- Klik "Confirm merge"